ACC-17 · Periodic Access Review & Entitlement Recertification

Without recertification, every grant becomes permanent by default. What is reviewed, on what cycle, by whom — and what actually happens when nobody answers.

Field	Value
Document ID	ACC-17
Version	1.0 · Known Good edition, by Kevin Zelman
Catalogue domain	B. Account Usage
Operating tier	Tier 4 — IT Management owns the cycle and receives the annual report. Tier 3 produces the lists; Tier 2 executes the removals. No tier of IT decides whether a person still needs access.
Review cycle	Annually, and after the first full cycle has run once.
Relationship to ACC-07	ACC-07 §8 already requires a quarterly privileged review and it stands unchanged. This document does not replace it; it places it in one calendar with the other eight review classes, so that a single cycle is planned and staffed rather than nine being separately remembered.

1. Purpose — the thesis, and the two cases behind it

Every access grant at the organization was made for a reason, on a particular day, by somebody solving a particular problem. Almost none of them are ever revisited. The reason expires, the project ends, the temporary worker's engagement ends, the person who granted it moves on — and the grant remains, because nothing in the system removes it and nobody is ever asked.

Without recertification, every grant becomes permanent by default. That single sentence is the argument for this document, and everything below is an attempt to make acting on it affordable.

Two ordinary cases:

- Several temporary-worker accounts are added to a departmental shared mailbox by a reply-all email thread. There is no form, no named mailbox owner and no review date. When those engagements end, the mailbox membership will not know it — and nothing else will ask.
- HR asks IT whether the old network drives are really going away while payroll-sensitive permissions are being reworked. The question is entirely reasonable. What it reveals is that nobody outside that piece of work can say who can reach payroll data, and that the only reason anybody is looking is that a migration forced it.

What this document is honest about from the start

This is written for small IT teams, where most staff wear several hats. A review cycle that cannot be staffed is a review cycle that does not run, and a document describing one is worse than nothing because it produces the appearance of a control.

So §2 lists fewer classes than a large organization would review, on longer cycles. §5 is deliberately softer than an auditor would prefer. Both are choices, stated as choices, with the reasoning shown — not aspirations quietly missed.

The measure of success in year one is not a clean estate. It is that every class in §2 has been reviewed once, that IT knows the response rate by department, and that the department heads who did respond saw something change as a result.

2. What is reviewed, and how often

This table drives the whole document. Everything after it is machinery for making these nine rows happen.

What is reviewed	Cycle	Reviewed by	List produced by	Why this cycle
Privileged and administrative role assignments (ACC-07)	Quarterly	Tier 4 with the role owner	Tier 3	Highest consequence per grant, smallest population. Already required by ACC-07 §8 — this is that review, in this calendar.
Vendor, contractor and consultant accounts (ACC-11)	Quarterly	The contract owner	Tier 3	The engagement can end without anybody telling IT. Reviewed against the current contract, not against memory of it.
Guest and sponsored external accounts (ACC-10)	Quarterly	The named sponsor	Tier 2	ACC-10 §6 already expires guests on non-response. This is the register review that sits behind that rule.
Shared mailbox membership, delegation and send-as (M365-03, ACC-14)	Semi-annual	The mailbox owner	Tier 2	Membership grows by reply-all and nothing removes it. The most reliably productive review on this list.
SharePoint site membership and external sharing (M365-10, M365-11, M365-14)	Semi-annual	The site owner	Tier 2	Sharing links outlive the work that created them, and external sharing is the class where a stale grant reaches outside the organization.
Departmental and payroll-sensitive shares (M365-13, M365-15)	Semi-annual	The data owner	Tier 2	Low volume, high consequence. Reviewed separately from ordinary site membership so it is never the last section of a long list.

What is reviewed	Cycle	Reviewed by	List produced by	Why this cycle
Application access (the ACC-16 §10 register)	Annual	The application's business owner	Tier 3	Many applications, usually lower per-grant consequence — but an application without SCIM is not covered by the leaver process at all (ACC-16 §7), so this review is the only thing that reaches it.
Standard group membership (M365-04)	Annual	The group owner	Tier 3	For a dynamic group the object of review is the RULE, not the member list. Reviewing 400 auto-populated members is work that changes nothing.
Service, application and non-human accounts (ACC-08)	Annual	The account owner	Tier 3	No leaver process will ever reach these. If this review does not remove them, nothing will.

2.1 The calendar

Reviews are not issued into your peak periods, period-end closes or the first weeks after a large intake. The reviewers are department heads, and those are precisely the weeks in which they are busiest — a review sent then gets no response, which §5 then has to treat as a failure of the reviewer rather than of the scheduling. The freeze periods are the same ones GOV-04 §7 defines for changes, and they are honoured here for the same reason.

When	What runs	Note
Your peak periods	Nothing new.	The desk is busiest with joiners and temporary-worker onboarding (ACC-01, ACC-09), and reviewers are busy too. Nothing is asked of anybody.
Quarter 1, month 1	Quarterly: privileged, vendor, guest. Semi-annual round A: shared mailboxes and delegation, SharePoint sites and external sharing, departmental and payroll-sensitive shares.	The heaviest month by design. Place it where reviewers are available and access patterns have settled.
Quarter 1, month 2	Remediation from month 1. No new packets.	
Quarter 2, month 1	Quarterly: privileged, vendor, guest.	A deliberately light month.
Quarter 2, month 2	Annual round: application access, standard group membership, service and non-human accounts.	The longest lists, placed in your quietest month.
Quarter 2, month 3	Remediation. Exceptions reaching expiry are notified.	
Quarter 3, month 1	Quarterly: privileged, vendor, guest. Semi-annual round B.	Issued after any peak period, never during one.

When	What runs	Note
Quarter 3, month 3	The annual report to Tier 4 (§9).	The one output the Head of IT actually reads.
Quarter 4, month 1	Quarterly: privileged, vendor, guest.	Small populations; a good fit for a quiet month.

Map the quarters onto your own year so that no round lands in a peak period.

---

3. Who reviews — and why it is never IT

The accountable manager or data owner reviews. Not IT, not the service desk, and not the person who happens to administer the system.

The reason is not a division of labour, it is a limit on knowledge. IT can see that a person HAS access. IT cannot see whether they still NEED it, because that depends on what the person does now, what the department has reorganised, which project ended last quarter and whether last year's cover arrangement is still in place. A review answered by IT confirms the current state — which is precisely the thing being questioned.

> **The counter-argument, and why it does not change the answer**
>
> Managers do not want to do this. It takes time they do not have, it is not their job as they understand it, and asking them is unpopular. All of that is true and none of it is a reason to move the decision.
>
> The alternative fails in both directions. If IT removes access on its own judgement, it will eventually remove something somebody needed, and the department will stop co-operating with the process entirely — which costs far more than the grant that was removed. If IT keeps everything to avoid that, the review is theatre and produces evidence of a control that is not operating, which is worse than having no control at all.
>
> What IT can do is make it cheap. That is §4, and it is the part of this document that determines whether any of the rest of it happens.

3.1 IT's three jobs

1. Produce the list — accurately, from the platform, for the whole class rather than the part that is easy to extract.
2. Make it readable — §4. A list a department head can act on in ten minutes gets acted on; a list of object IDs gets approved wholesale.
3. Act on the answer, promptly and visibly. A reviewer who spends forty minutes on a review and sees nothing change will not do the next one, and there is no recovering from that. Removals are executed within the §6 service level and the reviewer is told they were done.

3.2 The reviewer of record

- Every review class has a named reviewer of record, identified BEFORE the packet is issued. Chasing down who should answer after the packet has gone out wastes the review window.

- Where no reviewer can be identified, that is the finding. An entitlement with no accountable owner is removed rather than researched — the same rule ACC-10 §6 applies to a guest with no identifiable sponsor.
- A reviewer may delegate to a named deputy in writing, and remains accountable for the answer.
- Where the reviewer has left the organization, their successor or their manager is substituted before the packet is issued, not during it. This is a small check that prevents a whole round being lost to an unread mailbox.

---

4. The review packet

The single biggest determinant of whether a review is done properly is whether the list is readable. A spreadsheet of four hundred rows of group object identifiers will be approved in four minutes, and that approval is worse than worthless — it produces evidence that a review took place.

4.1 What each row contains

- The person's full name and current role. Not the UPN alone, and certainly not the object ID.
- What they can reach, in plain words — "read and write to the Payroll folder", not "member of Y-PAYROLL-RW".
- How they got it: who requested it, on what date, and the ticket reference where one exists. Frequently this column is empty, and an empty column is itself informative.
- Last used, where the platform can tell us — and an honest note where it cannot. Sign-in dates are available for accounts; last use of a specific permission usually is not. A blank column reads as "never used" and will get things removed for the wrong reason.
- Three boxes: Keep, Remove, Change — with a free-text line for Change.

4.2 Rules about the packet itself

- Nothing is pre-filled, and there is no "approve all" control. If approving everything is one click, that is what the data will say happened.
- Rows are sorted with the highest-risk first: external and guest access, privileged assignments, and dormant accounts. Attention runs out before the list does, so it is spent where it matters.
- A packet longer than about fifty rows is split by department or by site. Batch by the reviewer's world, not by the system's.
- The due date is stated on the packet as a date, not as a number of days.
- Appendix A goes with every packet, every time, including to reviewers who have done it before.
- The packet says what will happen if there is no response (§5). Nobody should be surprised by an escalation they were not warned about.

---

5. What "no response" means

It does not mean approval. A grant that nobody is willing to confirm is a grant nobody is accountable for, and treating silence as a Keep would make the whole exercise a formality.

What this document does not do is convert that into automatic revocation on day eleven, and it is worth being explicit about why, because auto-revoke is what best practice recommends and what an auditor will ask for.

> **Why an aggressive auto-revoke is the wrong control at this organization**
> An auto-revoke does not fire against the least justified entitlement. It fires against the busiest reviewer — the department head covering two roles who did not open the email, whose own access to their own share then disappears in the middle of the week.
> It generates P1 restoration tickets on a desk where lockouts are already among the largest ticket categories, which means the review cycle becomes a source of the very work it was meant to reduce.
> And it only has to happen twice before everybody in the organization learns that the correct response to a review email is to approve everything immediately without reading it. At that point the control is inverted: it looks better in the evidence and it is worth nothing.
> The model below is escalate-then-revoke with a stated grace period. It is slower than best practice and it is a control the organization can actually operate, which is the trade every document in this catalogue tries to make.

5.1 The escalation ladder

Day	Action	By
0	Packet issued with the due date stated as a date, and with Appendix A attached.	Tier 3
10	No response: an individual reminder to the reviewer, by name, with the list attached again. Not a broadcast — a broadcast reminder is read as noise and reaches the people who already responded.	Tier 2
15	No response: escalated to the reviewer's manager, with the list and the date the packet was issued.	Tier 3
20	No response: the entitlements are listed for revocation. The reviewer and their manager are told the exact date on which it will happen, and the list goes to Tier 4.	Tier 4
25	Grace period ends. Revocation proceeds for everything on the list, except where Tier 4 has recorded a specific hold with a reason.	Tier 2

That is a twenty-five coverage-day grace period from issue to removal. It is longer than an auditor would like, and it is the interval at which the organization can hold the line without the process collapsing.

5.2 Two classes that are outside this ladder, deliberately

- An entitlement with NO IDENTIFIABLE OWNER is removed at day 20 with no further escalation, because there is nobody to escalate to. Researching who might once have wanted it costs more than restoring it if somebody objects (§6).
- PRIVILEGED assignments follow ACC-07 §8, where anything unconfirmed is removed. The population is small, the reviewers are Tier 4 themselves, and the consequence of a stale administrative role is high enough to justify the harder rule. The two documents differ on purpose, and this paragraph exists so that the difference is not read as an inconsistency to be tidied away.

5.3 Capacity, and why the cycle extends rather than lapses

Where the department is in a declared Constrained or Degraded capacity state (GOV-06 §7), each stage of §5.1 moves by the length of the declared state, the extension is recorded on the review itself, and the annual report says how many days were lost to capacity.

- Under Constrained: packets already issued continue on the extended ladder. New packets may be deferred to the next month, with the deferral recorded.
- Under Degraded: issuing new packets is suspended. Remediation of answers already received continues, because removing access is cheap and reviewing it is not.
- A suspended round is made up, not skipped. The next round covers the interval since the last completed one, and the report says so. A review missed silently teaches nobody anything and is discovered a year later by an auditor. A review visibly extended, with the days counted, is a fact about staffing that Tier 4 can act on — which is the entire purpose of the GOV-06 states.

---

6. Remediation, and its service level

Outcome	Action	Commitment (per GOV-06)
Keep	Recorded with the reviewer's name and the date. Nothing changes.	n/a — but it is recorded, because next year's review starts from it (§8).
Remove	Access revoked.	Within 5 coverage days of the response.
Change (reduce)	Reduced to the level the reviewer stated.	Within 5 coverage days.
Keep, but the reviewer cannot say why	Treated as an exception under §7 with a 90-day expiry, not as a Keep. The distinction matters: a Keep is a decision, this is a deferral.	Exception recorded within 5 coverage days.
A removal that turns out to be wrong	Restored on request. No argument, no re-approval, and the restoration is recorded as a defect in the review rather than as a fault of the requester.	Within 1 coverage day.
An entitlement that should never have been granted	Not a remediation item. Referred to GOV-03 as a question about whether anything was accessed — specifically where it is privileged, payroll-sensitive or client-record access held by somebody with no business need.	Same day referral.

- Removals are executed, not scheduled indefinitely. An unactioned removal is the worst available outcome: the department has spent the effort and the risk is unchanged.
- Where a removal would break something — a mailbox rule, an integration, a service account dependency — it is staged and the dependency is recorded. That dependency is itself a finding for ACC-08, because it means a person's access is load-bearing for an automated process.
- The reviewer is told when their removals have been done. This is the cheapest thing on the list and it is what buys next year's co-operation (§3.1). IT restores first and asks afterwards. A department that has to argue its way back to access it needed will not co-operate with the next review, and that co-

operation is the only mechanism holding this document up.

7. Exceptions

- Every exception records four things: what is being excepted, why, who approved it, and the date it expires. There are no open-ended exceptions.
- Maximum initial term twelve months. Renewal is a fresh approval by the same authority, not a roll-over.
- An expired exception reverts to the rule automatically. Nobody has to remember, which is the point.
- The exception register goes to Tier 4 in the annual report with the age of each entry.
- An exception renewed three times is not a special case — it is evidence that the rule is wrong. Raise it as a change to the governing document under GOV-01 rather than renewing it a fourth time.

8. Evidencing the review

The evidence is the reviewer's answer, not IT's summary of it. The returned packet is kept as returned.

- Kept per round: the packet as issued, the response with the reviewer's name and date, the actions taken with their dates, the exceptions raised, and every escalation under §5.1.
- An approval with no identifiable individual behind it is not evidence of a review. "Approved by the department" is not a reviewer. There is a second, more practical reason to keep the answers, and it matters more day to day than the audit one: the next review starts from the last one. A reviewer shown "you approved these twenty-four rows last round; here are the three that have changed since" completes a review in five minutes rather than forty, and reads the three properly. Full lists are issued annually; the intermediate rounds are deltas against the last completed answer.

That is also why the first cycle is the expensive one, and why it should not be judged by how long it takes. Everything after it is cheaper because of it.

9. The annual report to Tier 4

One report a year, at the same point each year, covering the previous twelve months. It is short and it is the mechanism by which this document survives contact with a busy year.

- Entitlements reviewed, by class, against what §2 says should have been reviewed.
- Response rate by class and BY DEPARTMENT, with departments named. An anonymised response rate changes nobody's behaviour.
- Counts removed, reduced and kept — and the ratio, which is the number that says whether the review is finding anything.
- Open exceptions with their ages, and any renewed more than twice (§7).
- Entitlements found with no identifiable owner, by system. This is usually the most uncomfortable and most useful section.
- Days lost to declared Constrained or Degraded capacity states (§5.3).
- Three findings the Head of IT should act on, named as such. Not a list of everything observed.

> **And it says plainly if the cycle did not run**
> A year in which two rounds were skipped is a staffing statement, and the report makes it rather than quietly reporting on the rounds that did happen.
> The most useful number in this report is usually the response rate. The most useful sentence is usually about a department rather than a system.

10. Service levels

Activity	Commitment (per GOV-06)
Review packet produced and issued	On the §2.1 calendar. Deferred only under a declared capacity state, and recorded.
Reviewer response window	10 coverage days, stated on the packet as a date.
Removals and reductions after a response	5 coverage days.
Restoration of an incorrect removal	1 coverage day. No re-approval required.
Escalation to the reviewer's manager	Day 15 of the ladder (§5.1).
Revocation after the grace period	Day 25, with the date given in advance.
Referral of an entitlement that should never have existed	Same day, to GOV-03.
Annual report to Tier 4	Once a year, on schedule.

11. Records

Record	Held in	Retention
Review packets as issued	IT governance record	3 years
Reviewer responses, named and dated	IT governance record	3 years; 7 for privileged and payroll-sensitive classes
Actions taken, with dates	Ticket + governance record	3 years
Escalations and non-responses	IT governance record	3 years
Exception register	IT register	Life of the exception + 3 years
Entitlements removed for having no identifiable owner	IT governance record	3 years
Annual report to Tier 4	Tier 4 record	Permanent

12. Related documents

ID	Title	Relationship
ACC-07	Privileged & Administrative Account Standard	§8 there is the quarterly privileged review. Its harder non-response rule is preserved (§5.2).
ACC-08	Service, Application & Non-Human Account Standard	The annual class no leaver process reaches.
ACC-09	Temporary Worker & Departmental Access Account Standard	The engagement boundary should remove most temporary-worker grants before a review has to.
ACC-10	Guest & Sponsored External Account Standard	§6 there already expires guests on non-response; this is the register review behind it.
ACC-11	Vendor, Contractor & Consultant Account Standard	The quarterly vendor class, reviewed against the current contract.
ACC-14	Mailbox & Calendar Delegation Standard	Delegation and send-as are reviewed semi-annually.
ACC-16	Application Onboarding, SSO & SAML Claims Standard	§10 there is the register this document's annual application review runs off.
ACC-01	Account Lifecycle	The mover procedure should remove what a role change ends; this review catches what it missed.
M365-03	Shared Mailbox Standard	Mailbox owner is the reviewer of record.
M365-11	SharePoint & OneDrive Permissions	Site membership and permission inheritance.
M365-14	External Sharing & Guest Access	External sharing links, reviewed semi-annually.
M365-13	File Share Retirement Runbook	The migration is the cheapest moment to set the baseline.
M365-04	Distribution List & Dynamic Group Standard	For a dynamic group the rule is reviewed, not the members.
GOV-06	Service Commitments, Priority & Escalation	§5.3 capacity states, and §10.
GOV-03	Security Incident Response	Where an entitlement that should never have existed goes.
GOV-01	SOP Catalog Governance	Where a thrice-renewed exception is raised as a rule change.

Appendix A — The reviewer's one-page instruction sheet

Sent with every packet. Written so that a department head can act on it without training and without asking anybody what it means.

What this is	A list of the people who currently have access to something you are responsible for. We are asking you to confirm whether each of them should still have it. We are not suggesting anything is wrong — this is a routine check we run on a schedule.
Why we are asking you and not deciding ourselves	We can see who has access. We cannot see whether they still need it. Only you know whether that project finished, whether the cover arrangement is still running, or whether somebody has changed roles. If we guessed, we would either take away something you need or keep everything, and neither is any use to you.
What we need from you	For each line: Keep, Remove, or Change. If you choose Change, tell us in a few words what they should have instead. That is the whole task.
How long it takes	Most lists take about ten minutes. If yours is long enough that it does not, tell us — that usually means we have batched it wrongly and we will split it.
Four questions that make it quick	1. Do they still do the work this access was for? 2. If they asked you for it today, would you say yes? 3. Do they need this much, or would less do? 4. Do you recognise the name at all?
If you are not sure	Choose Remove. If it turns out somebody needed it, we will put it back the next working day, with no argument and no form to fill in. Keeping something “just in case” is exactly how these lists get longer every year.
If a name means nothing to you	Say so. An entitlement nobody can account for is one we should not be carrying, and telling us that is genuinely one of the most useful answers you can give.
If you are not the right person	Tell us who is, and we will send it to them and update our records. This is the single thing that will most reduce the time this takes you next time.
What happens next	We make the changes within five working days and tell you they are done. Your answers are kept, so next time we will send you only what has changed since — which usually takes about five minutes.
What happens if you do not reply	We will remind you at ten working days, and let your manager know at fifteen. At twenty working days we will tell you the date on which the access will be removed, and at twenty-five we remove it. We would much rather have your answer than do that.
If you need more time	Ask. A short extension recorded on the review is entirely normal, and it is far better than a rushed approval or a silence we have to escalate.
Who to ask	Reply to the message that sent you this list, or contact the service desk, quoting the review reference at the top of your packet.

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.